2025-2026

BRUTE FORCE ATTACK

Analyse et protection contre les attaques par force brute sur une application web



Présenté devant le jury : Othmane ....

Manal Elhani - Wissal Elbekkali - Zineb Elhadri - Ayman Bouissehak



PROBLÉMATIQUE

Comment une application web peut-elle résister à une attaque par force brute ?

Les mécanismes d'authentification reposant uniquement sur un nom d'utilisateur et un mot de passe constituent l'un des points les plus vulnérables des applications web. L'utilisation fréquente de mots de passe faibles, combinée à l'absence de mécanismes de protection tels que la limitation des tentatives ou les CAPTCHA, permet l'automatisation des tentatives de connexion. Cette situation augmente considérablement le risque de compromission des comptes utilisateurs et souligne la nécessité de mettre en place des mesures de sécurité adaptées.

Protéger les données

Renforcer la réputation

OBJECTIFS

The Growing Threat Landscape

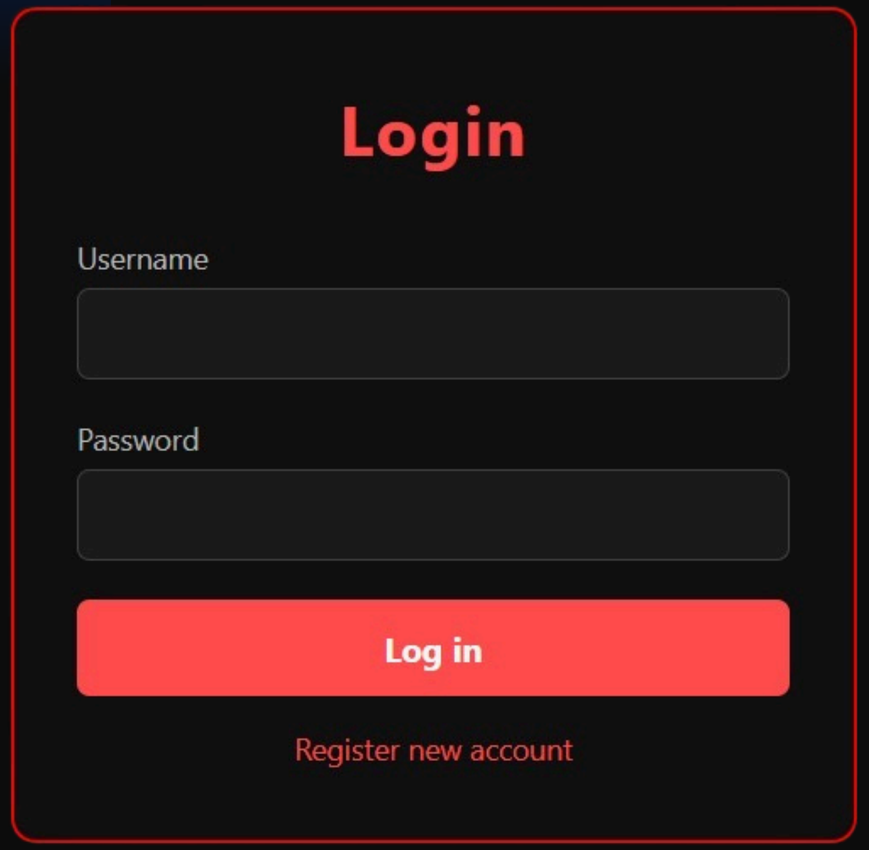
Afin de mener ce projet de manière structurée et cohérente, des objectifs précis ont été définis. Ces objectifs permettent de guider l'analyse du problème, d'orienter la mise en œuvre technique des différentes solutions et d'assurer une démarche méthodologique claire. Ils servent également de base pour évaluer l'efficacité des mécanismes de sécurité proposés, en comparant le comportement de l'application avant et après sa sécurisation.



- Comprendre le fonctionnement des attaques par force brute
- Analyser l'impact des attaques automatisées sur une application web
- Mettre en œuvre des mécanismes de protection efficaces
- Comparer le comportement de l'application avant et après sécurisation

PRÉSENTATION DE L’APPLICATION WEB

L’application utilisée dans le cadre de ce projet est une application web développée et déployée dans un environnement local, afin de garantir un cadre strictement pédagogique et sécurisé. Elle repose sur un formulaire d’authentification classique utilisant un nom d’utilisateur et un mot de passe. Un compte utilisateur de test a été créé pour les besoins de la démonstration. Dans sa version initiale, l’application a été conçue volontairement sans mécanismes de protection, ce qui permet d’analyser son comportement face à une attaque par force brute avant toute sécurisation.



OUTILS UTILISÉS



BURP SUITE

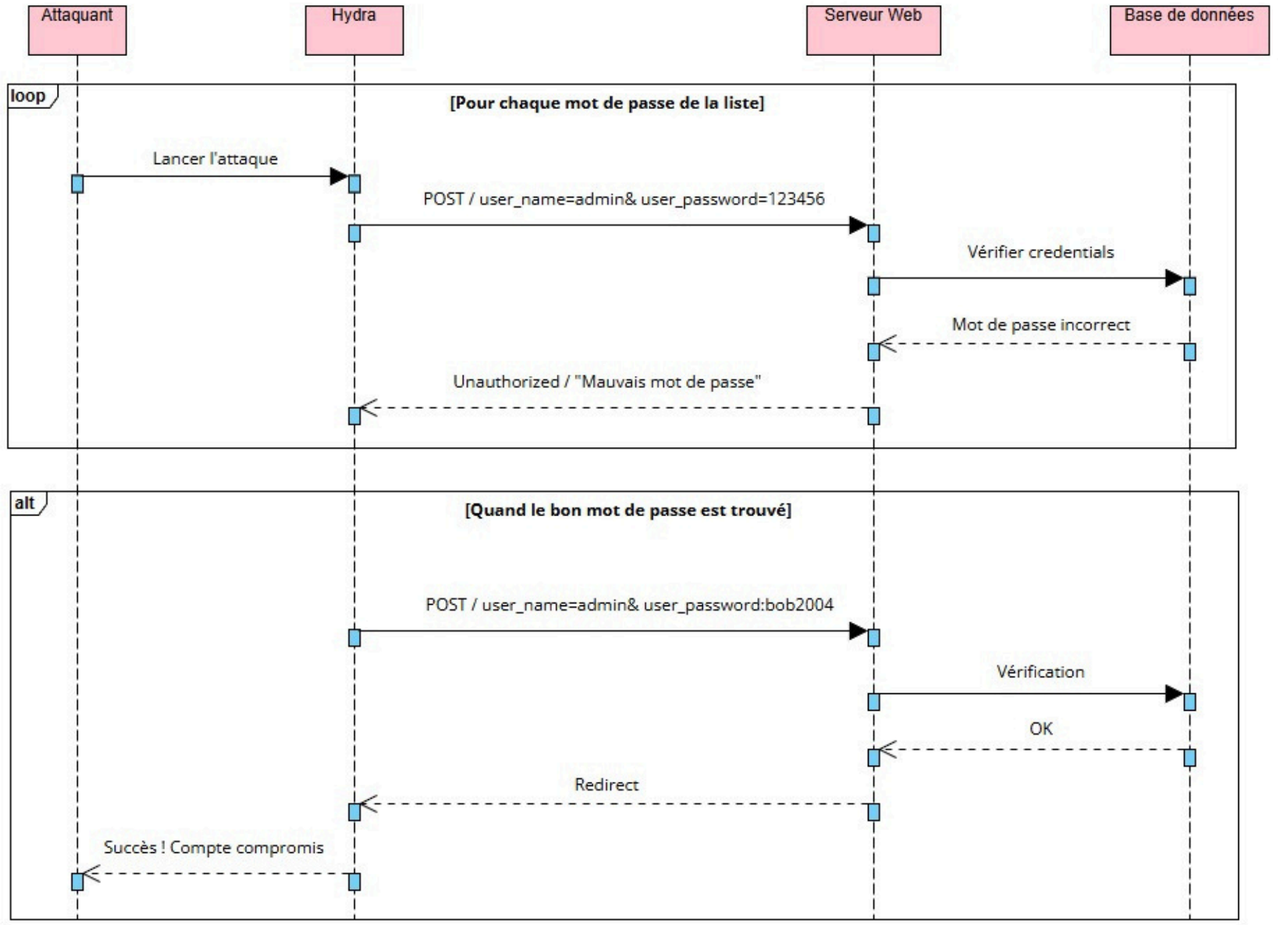


HYDRA

Afin de mener la démonstration de l'attaque par force brute et d'analyser le comportement de l'application, des outils spécialisés en sécurité des applications web ont été utilisés. Burp Suite a permis d'intercepter et d'analyser les requêtes HTTP échangées entre le navigateur et le serveur, ainsi que d'identifier les paramètres du formulaire de connexion. Hydra a ensuite été utilisé pour simuler une attaque par dictionnaire automatisée, en testant successivement plusieurs mots de passe. Ces outils ont été employés exclusivement dans un environnement local et à des fins pédagogiques.

SCÉNARIO D'ATTAQUE (AVANT SÉCURITÉ)

Diagramme de séquence - Brute force



Dans cette phase, l'application ne dispose d'aucun mécanisme de protection contre les attaques par force brute. L'absence de limitation du nombre de tentatives et de vérification humaine permet l'envoi automatisé de multiples requêtes de connexion. À l'aide des outils d'analyse et d'attaque, il est alors possible de tester successivement plusieurs mots de passe jusqu'à l'obtention d'un accès valide, démontrant ainsi la vulnérabilité de l'application non sécurisée.

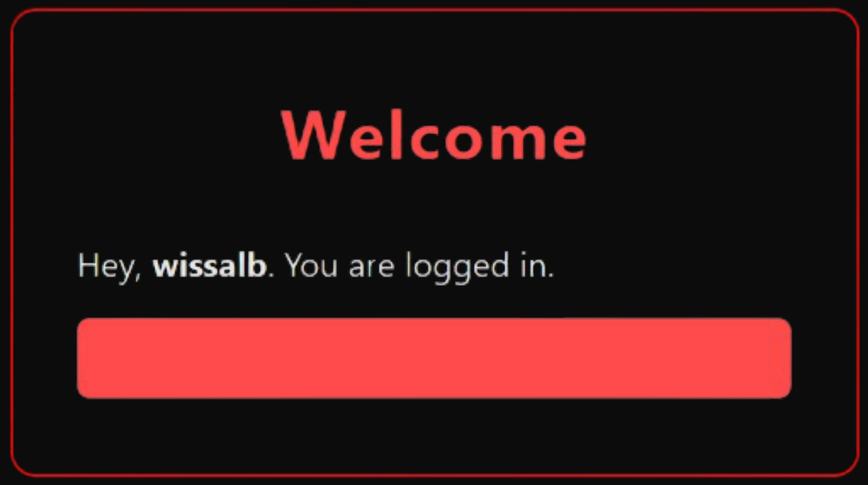
RÉSULTATS OBSERVÉS (AVANT SÉCURISATION)




```
┌──(kali㉿kali)-[~]
└─$ hydra -l zinebb -P wordlistbf.txt 192.168.1.37 http-post-form \
"/php-login-minimal/index.php:user_name=^USER^&user_password=^PASS^&login=Login:S=You are logged in"
-t 4 -w 3 -I

Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret serv
-binding, these *** ignore laws and ethics anyway).

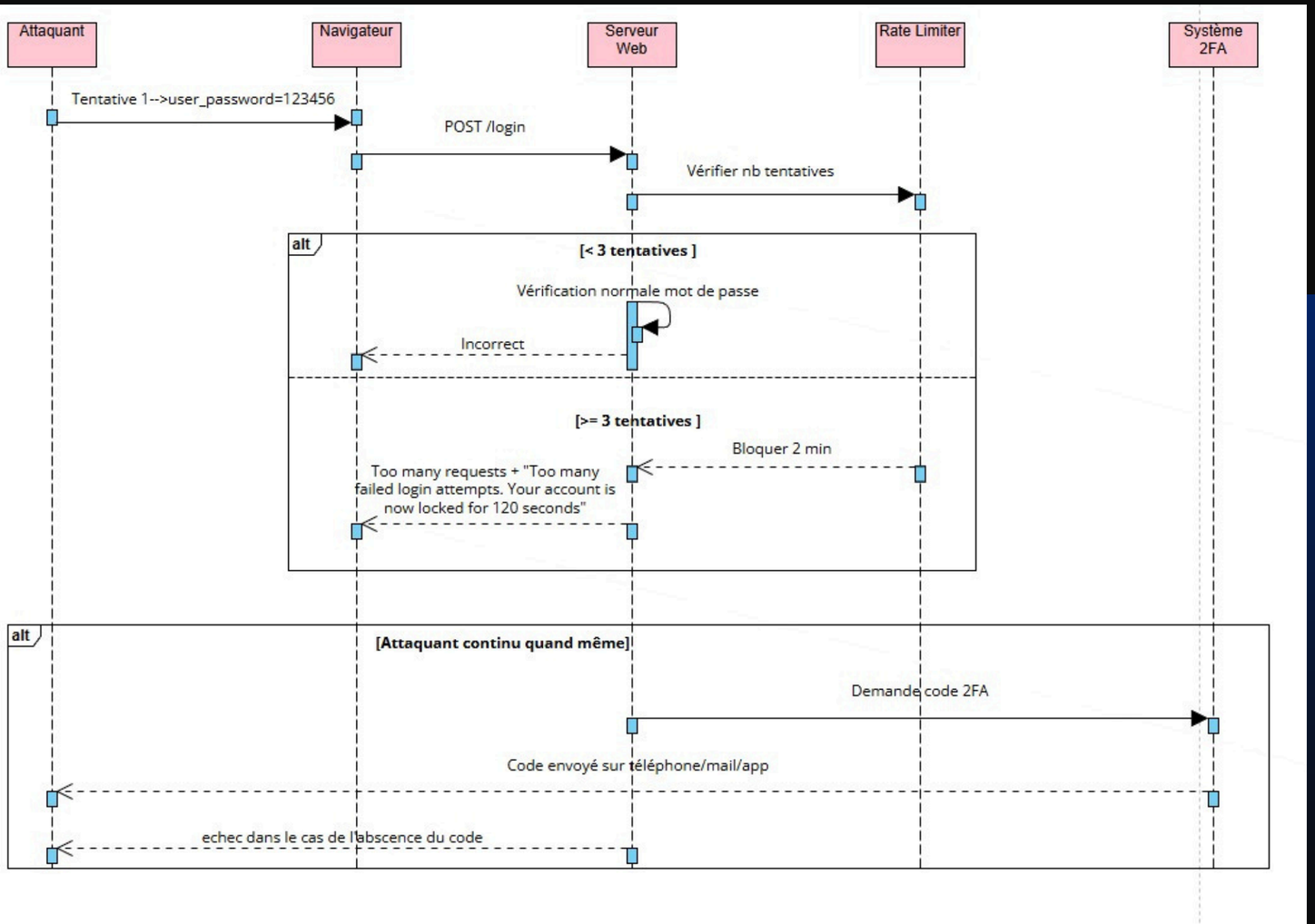
[WARNING] the waittime you set is low, this can result in errornous results
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-12 12:51:16
[DATA] max 4 tasks per 1 server, overall 4 tasks, 43 login tries (l:1/p:43), ~11 tries per task
[DATA] attacking http-post-form://192.168.1.37:80/php-login-minimal/index.php:user_name=^USER^&user_p
[80][http-post-form] host: 192.168.1.37   login: zinebb   password: elbekkali
1 of 1 target successfully completed, 1 valid password found
```



Les résultats observés avant la mise en place des mécanismes de sécurité montrent que l'application est fortement vulnérable aux attaques par force brute. L'absence de limitation des tentatives permet l'envoi illimité de requêtes de connexion automatisées. Dans ces conditions, un mot de passe faible peut être identifié en quelques secondes, ce qui conduit à l'obtention d'un accès valide et à la compromission du compte utilisateur.

SCÉNARIO D'ATTAQUE (APRÈS SÉCURITÉ)

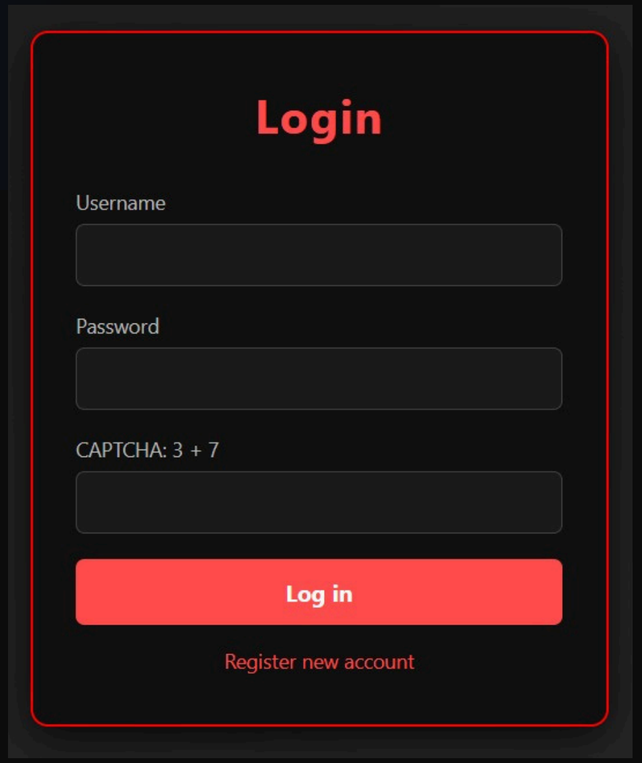
Diagramme de séquence - Brute force

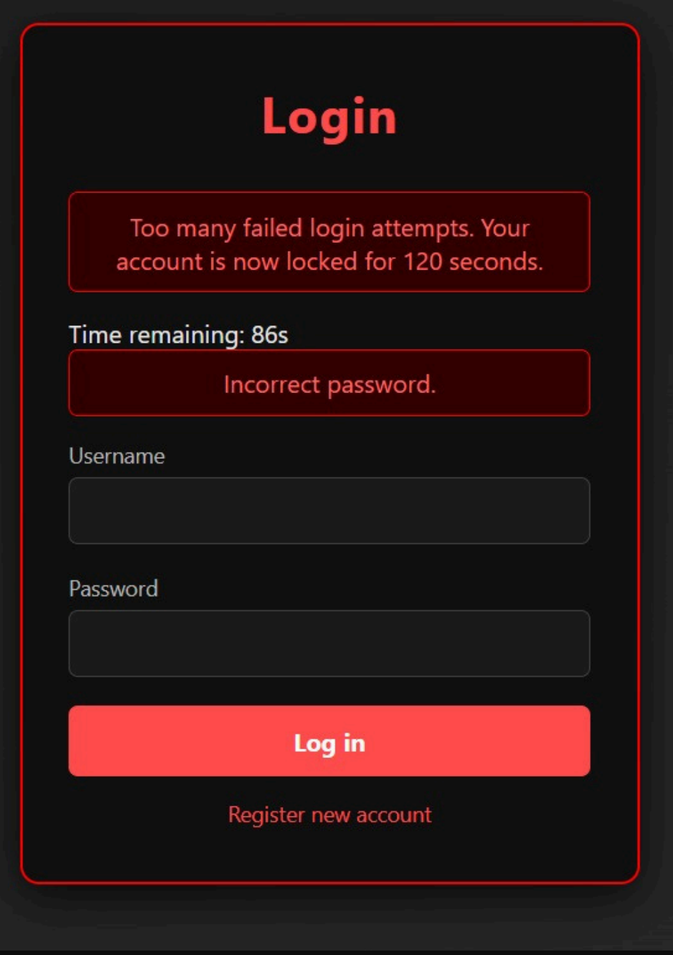


Après la mise en place des mécanismes de sécurité, le comportement de l'application face aux attaques par force brute a été significativement modifié. La limitation du nombre de tentatives de connexion à trois essais consécutifs entraîne un verrouillage temporaire du compte en cas d'échec répété. De plus, l'intégration d'un CAPTCHA obligatoire permet de bloquer l'automatisation des requêtes. Ces mesures rendent l'attaque par force brute inefficace et empêchent l'obtention d'un accès non autorisé.

RÉSULTATS OBSERVÉS (APRÈS SÉCURISATION)

Après la mise en place des mécanismes de sécurité, le comportement de l'application face aux attaques par force brute a été significativement modifié. La limitation du nombre de tentatives de connexion à trois essais consécutifs entraîne un verrouillage temporaire du compte en cas d'échec répété. De plus, l'intégration d'un CAPTCHA obligatoire permet de bloquer l'automatisation des requêtes. Ces mesures rendent l'attaque par force brute inefficace et empêchent l'obtention d'un accès non autorisé.






```
┌──(kali㉿kali)-[~]
└─$ hydra -l wissal6 -P wordlistbf.txt 192.168.1.35 http-post-form \
"/php-login-minimal/index.php:user_name=^USER^&user_password=^PASS^&login=Login:S=You are logged in" \
-t 4 -w 3 -I
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

[WARNING] the waittime you set is low, this can result in errornous results
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 14:29:07
[DATA] max 4 tasks per 1 server, overall 4 tasks, 43 login tries (l:1/p:43), ~11 tries per task
[DATA] attacking http-post-form://192.168.1.35:80/php-login-minimal/index.php:user_name=^USER^&user_password=^PASS^&login=Login:S=You are logged in
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-16 14:29:10
```

DÉMONSTRATION

Pour illustrer concrètement ces résultats, nous vous laissons maintenant avec une courte vidéo de démonstration.

COMPARAISON

La comparaison entre l'application non sécurisée et l'application sécurisée met clairement en évidence l'impact des mécanismes de protection mis en place. Avant la sécurisation, l'attaque par force brute aboutit rapidement à l'obtention d'un accès valide en raison de l'absence de limitations et de contrôles. Après l'ajout de la limitation des tentatives de connexion et du CAPTCHA, l'attaque est bloquée dès les premières tentatives, rendant l'automatisation inefficace et protégeant les comptes utilisateurs.

MERCI POUR ATT



hhhhgg

nnnnn

bbbb